EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

PLAN-MFA

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Scope
3. Objectives
4. Responsibilities
5. MFA Implementation Plan
6. Incident Management
7. Review
8. Compliance Alignment

PLAN-MFA

1. Purpose

To enhance security and ensure compliance with NIST 800-171 and CMMC 2.0 Level 2 by implementing Multi-Factor Authentication (MFA) using Microsoft Authenticator for O365 GCC High access and Duo for local device protection.

2. Scope

This plan applies to all users (employees, contractors, and third-party associates) accessing the organization's systems, including O365 applications, local devices, and other sensitive resources.

3. Objectives

1. Secure access to Office 365 GCC High using Microsoft Authenticator as one of the MFA methods, along with Duo as an alternate option.
2. Protect local device access using Duo MFA to mitigate risks from unauthorized access or credential compromise.
3. Ensure compliance with regulatory standards, including NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2.
4. Provide seamless user experience while maintaining strong security measures.

4. Responsibilities

- **Security Administrator**:
  - Oversee the deployment and management of MFA tools.
  - Monitor MFA logs and troubleshoot user access issues.
  - Ensure all devices and accounts are enrolled in the appropriate MFA solution.
  - Verify that MFA implementations align with organizational and regulatory policies.
- **Users**:
  - Enroll in Microsoft Authenticator for O365 access and Duo for local device MFA.
  - Report issues or incidents involving MFA promptly.

5. MFA Implementation Plan

5.1 Office 365 GCC High (O365) Access Using Microsoft Authenticator

1. **Enrollment**:
   - Microsoft Authenticator is one of the MFA methods for O365 GCC High.
   - Users must download and configure Microsoft Authenticator on their mobile devices.
   - Duo or any other authenticator app can be used as an alternative MFA method.
   - SMS can be used as an alternative MFA method.
   - YubiKeys can be used as an alternative MFA method.
2. **Configuration**:
   - Enable MFA for all O365 accounts via Microsoft Entra ID Conditional Access Policy.
3. **User Training**:
   - Provide users with support as required for Microsoft Authenticator setup and troubleshooting.
   - Emphasize the importance of using MFA for protecting O365 accounts.

5.2 Local Device MFA using Duo

1. **Deployment**:
   - Duo is configured as the default MFA tool for securing local device access, including laptops, and desktops.
   - Devices must have Duo's client software installed and linked to the user's profile.
2. **Enrollment**:

- *Security Administrators* will initiate Duo enrollment for each user. Users will verify their identity and register their mobile device or security token.
- Duo will enforce MFA for login attempts to local devices.

1. **Policy Enforcement**:
   - Enable MFA for all local device logins.
2. **Fallback Mechanisms**:
   - Provide offline MFA methods, such as hardware tokens or offline-based one-time passcodes, to ensure accessibility in low-connectivity scenarios.

6. Incident Management

1. **MFA Issues**:
   - Users experiencing MFA difficulties (e.g., lost devices, app errors) must report to the *Security Administrator* immediately.
   - *Security administrators* will disable lost device tokens and provide temporary access methods until the issue is resolved.
   -

Security administrators will disable lost device tokens and provide temporary access methods until the issue is resolved.

2. **Security Breaches**:
   - In the event of unauthorized access, immediately disable the affected user account and investigate using MFA logs.
   - Require re-enrollment in MFA for compromised accounts as per the **SOP-USRMGT**.

7. Review

1. **Periodic Reviews**:
   - Evaluate MFA Policies effectiveness bi-annually as part of the **PLAN-RVWITMS**.
   - Update MFA policies as needed to adapt to evolving security threats or compliance requirements as per the latest threat intelligence from sources.

8. Compliance Alignment

This plan supports compliance with NIST 800-171 and CMMC 2.0 Level 2 requirements by:

- Enforcing multi-factor authentication for privileged and non-privileged accounts.
- Logging and monitoring access attempts for audit and review.

9. Review and Update Plan

This plan will be reviewed and updated annually or after significant changes in MFA tools, organizational structure, or regulatory requirements.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "PLAN-MFA".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of PLAN-MFA (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026